

Security+ 2.4 · Denial of Service

Mestre CyberSec — PDF baseado na aula do Professor Messer · 2.4 — Denial of Service (6:07) · [vídeo original ↗](#) · [YouTube ↗](#)

DoS (uma origem) derruba serviço; DDoS (distribuído — botnet de milhares de máquinas). Técnicas: amplification (requisição GRANDE pra servidor aberto que amplifica); SYN flood (meio handshake TCP deixa conexões penduradas); ICMP/ping flood. Defesa: CDN (Cloudflare/Akamai na frente), rate limiting, scrubbing service, autoscaling.

💡 Highlights que a prova cobra

- DoS/DoS: uma origem; DDoS: botnet de milhares — amplifica
- Amplification attack: req de 50 bytes gera resposta de 4000 (DNS/NTP abertos)
- Defesa principal: CDN / CloudFlare — absorve na borda antes de chegar

🎯 Dicas de prova

- 'thousands of machines send traffic simultaneously' = DDoS
- 'uses DNS or NTP servers to amplify traffic' = amplification attack

Cenário clássico: Cenário: 'um ataque derruba o serviço com tráfego de milhares de IP' = DDoS.

✅ Perguntas de treino (10 questões)

Gabarito no fim. Tenta responder SEM olhar.

1. Qual tipo de ataque explora vulnerabilidades antes que um patch esteja disponível?
A) Ataque de dia zero (Zero-day)
B) Ataque DDoS
C) Ataque de força bruta
D) Ataque Man-in-the-Middle

2. O framework NIST CSF organiza a segurança em 5 funções. Quais são?

- A)** Instalar, Atualizar, Testar, Auditar, Arquivar
- B)** Identificar, Proteger, Detectar, Responder, Recuperar
- C)** Planejar, Fazer, Checar, Agir, Revisar
- D)** Prevenir, Punir, Prever, Provar, Publicar

3. Cenário corporativo (Denial of Service): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'DoS/DoS: uma origem; DDoS: botnet de milhares — amplifica'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: DoS/DoS: uma origem; DDoS: botnet de milhares — amplifica...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

4. Cenário corporativo (Denial of Service): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Amplification attack: req de 50 bytes gera resposta de 4000 (DNS/NTP abertos)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Amplification attack: req de 50 bytes gera resposta de 4000 (DNS/NTP aberto...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Denial of Service): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Defesa principal: CDN / CloudFlare — absorve na borda antes de chegar'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Defesa principal: CDN / CloudFlare — absorve na borda antes de chegar...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Denial of Service): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'thousands of machines send traffic simultaneously' = DDoS'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'thousands of machines send traffic simultaneously' = DDoS...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Denial of Service): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'uses DNS or NTP servers to amplify traffic' = amplification attack'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'uses DNS or NTP servers to amplify traffic' = amplification attack...

8. Cenário corporativo (Denial of Service): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Cenário: 'um ataque derruba o serviço com tráfego de milhares de IP' = DDoS.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Cenário: 'um ataque derruba o serviço com tráfego de milhares de IP' = DDoS...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Denial of Service): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'DoS/DoS: uma origem; DDoS: botnet de milhares — amplifica'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: DoS/DoS: uma origem; DDoS: botnet de milhares — amplifica...

10. Cenário corporativo (Denial of Service): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Amplification attack: req de 50 bytes gera resposta de 4000 (DNS/NTP abertos)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Amplification attack: req de 50 bytes gera resposta de 4000 (DNS/NTP aberto...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO

- 1) A — Ataque de dia zero (Zero-day).** Zero-day é uma vulnerabilidade recém-descoberta que é explorada antes do desenvolvedor ter conhecimento ou lançar correção (dia zero de conhecimento).
- 2) B — Identificar, Proteger, Detectar, Responder, Recuperar.** NIST CSF = Identify, Protect, Detect, Respond, Recover. É o 'checklist mestre' citado em quase toda vaga. (A versão 2.0/2024 somou uma 6ª função, Govern — mas o SY0-701 ainda cobra as 5.) Decorar essas dá ponto fácil na
- 3) C — Implementar a solução correspondente: DoS/DoS: uma origem; DDoS: botnet de milha.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Denial of Service): DoS/DoS: uma origem; DDoS: botnet de milhares — amplifica. As demais alternativas configuram violações graves de co
- 4) C — Implementar a solução correspondente: Amplification attack: req de 50 bytes gera.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Denial of Service): Amplification attack: req de 50 bytes gera resposta de 4000 (DNS/NTP abertos). As demais alternativas configuram vi
- 5) A — Implementar a solução correspondente: Defesa principal: CDN / CloudFlare — absor.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Denial of Service): Defesa principal: CDN / CloudFlare — absorve na borda antes de chegar. As demais alternativas configuram violações
- 6) B — Implementar a solução correspondente: 'thousands of machines send traffic simult.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Denial of Service): 'thousands of machines send traffic simultaneously' = DDoS. As demais alternativas configuram violações graves de c
- 7) D — Implementar a solução correspondente: 'uses DNS or NTP servers to amplify traffi.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Denial of Service): 'uses DNS or NTP servers to amplify traffic' = amplification attack. As demais alternativas configuram violações gr
- 8) C — Implementar a solução correspondente: Cenário: 'um ataque derruba o serviço com .** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Denial of Service): Cenário: 'um ataque derruba o serviço com tráfego de milhares de IP' = DDoS.. As demais alternativas configuram vio
- 9) D — Implementar a solução correspondente: DoS/DoS: uma origem; DDoS: botnet de milha.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Denial of Service): DoS/DoS: uma origem; DDoS: botnet de milhares — amplifica. As demais alternativas configuram violações graves de co
- 10) B — Implementar a solução correspondente: Amplification attack: req de 50 bytes gera.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Denial of Service): Amplification attack: req de 50 bytes gera resposta de 4000 (DNS/NTP abertos). As demais alternativas configuram vi

